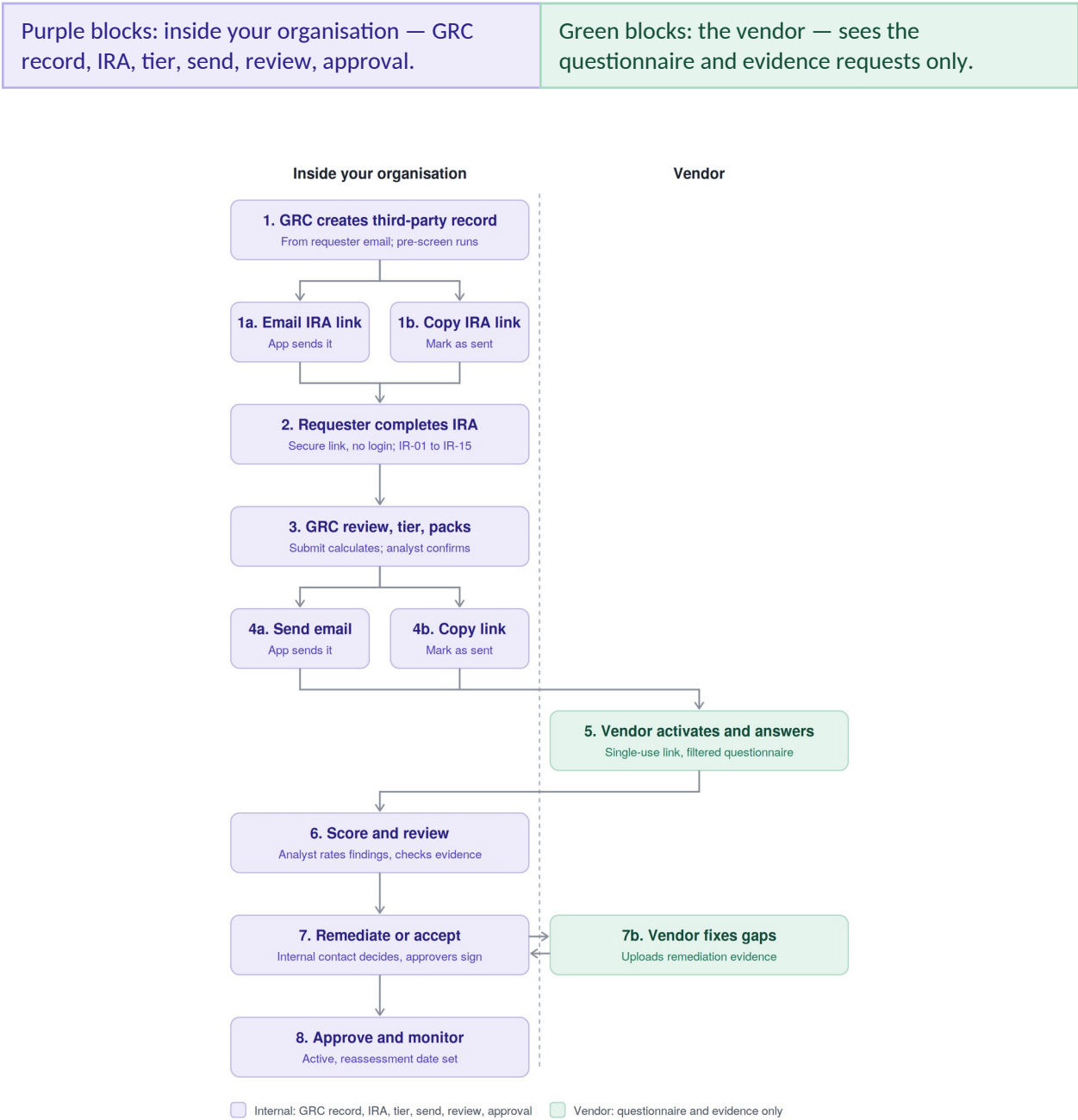


Third-party onboarding, step by step

How an engagement with a vendor moves from a requester's email to an approved, monitored relationship. Version 3 (final) — GRC creates the record; the requester completes a plain-language IRA through a secure link without app access; Part A facts pick the questionnaire packs, Part B impact sets the tier; an unanswered question means no tier; Low-tier vendors get a short baseline; scope changes are handled by addendum, never by rewriting. Each block says who acts, what they do, what the system does on its own, what the vendor can and cannot see, and what has to be true before the flow moves on. Read down the internal lane; the flow crosses to the vendor lane only where an arrow says so.



The flow in detail

1. GRC creates the third-party record

GRC / TPRM analyst — the requester has no access to the app at this point

Trigger

A requester (any employee) emails the GRC team or shared mailbox: who the vendor is and what they need it for. The requester is not a Supreme Risk user.

Analyst enters

Vendor legal name, website, country; what this engagement is for; business unit; estimated annual spend; target start date; the requester as internal contact (name and email). If the vendor already exists, this creates a new engagement under it rather than a duplicate; each engagement has its own IRA, tier and assessment, and the vendor's overall tier is the highest of its engagements.

System

- Creates the vendor (if new) and the engagement, with IDs like VND-2026-0142 / ENG-2026-0142-01.
- Runs external pre-screens through adapters: sanctions and adverse media; external security rating. A sanctions hit places the engagement on HOLD_SCREENING; a low rating is attached as a signal for step 3.
- Generates the IRA (Inherent Risk Assessment) for this engagement and a secure IRA link for the requester.

Moves on when the record is saved and screening is clear. **INTAKE**

▼ The IRA link is the requester's first touch — it reaches them in one of two ways

1a. Email the IRA link

App sends it

App does

Emails the requester: vendor and engagement name, what the IRA is for, the due date, and a button that opens the IRA directly — no account, no password.

Tracks

Sent time and delivery status (queued / delivered / bounced). A bounce reopens the requester email for correction and resend.

1b. Copy the IRA link

Analyst sends it their own way

App does

Shows the same secure link and a short suggested message to paste into the analyst's own reply to the requester, a chat, or the ticket.

Then

Click Mark as sent. The task and the 5-day clock start at that click.

Rules for both IRA delivery options

The IRA link works like the vendor link, because the requester has no login

- A task link, not an account: signed, tied to this engagement's IRA and the requester's email, opens only the IRA. It is a different token type from the vendor link — it can be opened as many times as needed to save and continue until submit, then shows a read-only confirmation. Expires 14 days after issue; regenerating invalidates the previous one.
- The same task-link mechanism is used every time this person is needed later (step 3 clarifications, step 7 decisions, change of scope, annual attestation), so they never need a Supreme Risk login.
- If the requester says someone else should answer, the analyst reassigns and a new link goes to that person; the hand-off is logged.
- Reminders on day 3 and day 5; escalation to the requester's manager on day 7 (copying GRC); withdrawn on day 14 if untouched.
- The audit log records which option was used, by whom, and when.

Moves on when the email is sent or the link is marked as sent. **INTAKE**

▼ Requester opens the IRA

2. Requester completes the IRA

Requester (internal contact) — via the secure link; plain-language, closed answers; nothing here is shown to the vendor

Part A — What will this vendor do? (facts)

Nine closed questions a business person can answer without guessing: what the vendor does for us (type of service), what information it will store or see, roughly how many people's records, what access it needs to our systems, whether it is public-facing or in a customer product, where data is handled, whether other companies are used to deliver it, whether it uses AI with our data, and whether it works on our premises. Every question has a "Don't know" option. The full list and answer choices are in Appendix A.

Part B — How bad if it fails? (impact)

Five closed questions: what happens if the vendor stopped tomorrow, whether a problem could cost material money, whether the service is tied to a law, licence or audit obligation, how bad a public failure would be for customers and reputation, and how hard the vendor would be to replace. Also with "Don't know".

Not asked

The requester never rates anything Low / Moderate / High and never sees the risk model. The system maps each answer onto the 15-factor model (IR-01 to IR-15) behind the scenes.

Vendor security contact

Name and email of the vendor's contact for the questionnaire. Optional if unknown — GRC can fill it at step 3.

Finish

Attest and submit. Drafts save on the link. Submit notifies GRC and runs the mapping: packs from Part A, score from Part B, floors from both.

Moves on when every question has an answer ("Don't know" counts as an answer) and the IRA is submitted. **TIER_REVIEW**

3. GRC review — tier and due-diligence requirements

System proposes; GRC analyst confirms — or the system auto-confirms Low

Packs come only from Part A (what the vendor does)

- **Baseline:** always (Lite or full — see below). **Personal and Sensitive Data:** any confidential, personal, payment, health, credential or regulated data. **Software and API:** the vendor supplies software, a hosted app or an automated connection. **Cloud Hosting:** the vendor hosts our data or systems. **Privileged and Network Access:** admin accounts, remote access or a network connection. **Physical Delivery:** on-site work or physical records/equipment. **Critical Operations:** only when B1 is "serious disruption within a week" or worse ("work-arounds" stays out). **Regulated Service:** B3 yes.

Tier comes from Part B plus floors from Part A

- Each mapped factor has a weight (3 = data type, privileged access, criticality, regulatory; 2 = integration, financial, dependency, brand, volume; 1 = the rest). Answers map to 0 / 1 / 2 points. Score = points ÷ maximum: under 20% Low, under 40% Medium, under 65% High, 65% and above Critical.
- **Floors:** payment, health, credential or regulated data; admin or network access; or "critical operations stop within a day" → Critical. Regulatory obligation, automated connection that changes our data, material financial loss, or personal data over 100,000 records → at least High. Any personal data → at least Medium, so it is always reviewed by GRC. Tier = the higher of the score band and any floor.
- **External rating:** SecurityScorecard below B (score under 80) or BitSight below 650, whichever is connected, raises the tier one level (never above Critical). The bump is applied first; auto-confirm is decided afterwards.

"Don't know" means no tier

While any answer is Don't know, the record shows "Not yet rated — N answers need confirmation" instead of a tier or a number. Auto-confirm cannot happen. GRC resolves each one with the requester (a clarification goes back through the requester's link) or from its own knowledge, recording the source; the tier is calculated only when nothing is unknown.

Analyst

- Accept the tier or override it with a written reason; add or remove packs with a note; enter or correct the vendor security contact.
- Due date in business days by tier: Critical 10, High 15, Medium 20, Low 25.

Baseline-Lite for Low

A Low-tier engagement receives the 14-question Baseline-Lite (Appendix C) instead of the full 45. Medium and above receive the full Baseline plus packs.

Auto-confirm

After any rating bump: tier Low, nothing unknown, no floor, a current external rating on file (missing or older than 90 days blocks), A8 (AI) not Yes, no override → confirmed by the system and ready to send; the analyst is informed. Medium and above always wait for the analyst. A8 = Yes shows GRC a note ("vendor uses AI with our data — review data use, model providers and human oversight") until the AI pack exists in workbook v1.1.

Moves on when the tier is confirmed with nothing unknown — Send stays disabled until then. ☐ **READY_TO_SEND**

4a. Send email

Analyst clicks Send

App does

Emails the vendor security contact: your organisation's name, the vendor name, the due date, and the activation link. Copies the internal contact.

Tracks

Sent time and delivery status (queued / delivered / bounced). A bounce reopens the contact field for correction and resend.

4b. Copy link

Analyst sends it their own way

App does

Shows the same activation link and a short suggested message to paste into the analyst's own email, a procurement thread or the vendor's ticket system.

Analyst

Sends it, then clicks Mark as sent. Nothing starts until that click.

Rules for both send options

Apply whether the app sent the email or the analyst copied the link

- One link, tied to this vendor and this assessment. Single use: once activated, opening it again is rejected.
- Expires after 14 days. Regenerating a link invalidates the previous one.
- Packs are locked at send so the vendor never sees questions appear or vanish mid-way.
- The audit log records which option was used, by whom, and when. The SLA clock starts at send or at Mark as sent.
- Reminders go to the vendor on day 7 and day 12; the internal contact is told on the due date; the analyst and procurement on day 25.

Moves on when the email is sent or the link is marked as sent. `AWAITING_VENDOR`

 Invitation link goes to the vendor

5. Vendor activates and answers

Vendor security contact, in the vendor portal

Sees

First, a short profile section to confirm hosting model, processing locations and subcontractors. If the vendor changes any of these, the change is recorded as a scope-change request for GRC (see step 6) — the questionnaire they are answering does not change. Then only the questions marked Answer — Baseline plus the packs selected in step 3 — with the control question, response guidance and expected evidence for each, grouped by domain. One evidence request per domain in scope.

Does

- Answers each question Yes / Partial / No / N/A and adds a comment (required for Partial, No and N/A).
- Uploads or links evidence against each domain; no passwords or secrets in uploads.
- Saves and resumes as often as needed, then submits. After submit the portal is read-only.

Never sees

Inherent risk answers, tier, question weights, scores, findings not marked for remediation, or any other vendor.

Portal

Own login, separate from your users. If the contact changes, the analyst updates it and regenerates the link.

Moves on when the vendor submits. **SUBMITTED**



Responses return to the analyst

6. Score and review

TPRM analyst

System

- Scores each answered question: Yes 0, Partial $2 \times \text{weight}$, No $4 \times \text{weight}$; N/A scores 0 and is excluded from the maximum.
- Residual risk = score $\div$ maximum: Low under 15%, Moderate under 35%, High under 60%, Critical 60% and above, shown overall and per domain.
- Creates a draft finding for every Partial or No, with severity from weight and answer.
- Marks each evidence request Received or Missing; flags audit reports older than 12 months.

Analyst

- Confirm, adjust (severity, with a note) or dismiss (with a reason) each draft finding.
- Mark evidence Accepted, Needs update or Rejected; a Needs update reopens that request for the vendor.
- Send a clarification request on any question; the vendor answers in the portal without reopening the whole questionnaire.
- Complete the review. SLA 5 business days (Critical and High: 10).

Scope change rule

If the vendor's profile confirmation (step 5) or anything learned in review would switch on a pack that was not sent, GRC reopens scope and issues an addendum assessment containing only the new pack(s), with its own due date. The original assessment, its answers and its findings are never rewritten. Tier is recalculated only if a Part A fact changed, and the change is logged.

Moves on when the analyst completes the review and any addendum is closed. Straight to step 8 if there are no findings. FINDINGS_OPEN

▼ Each finding needs a decision

7. Remediate or accept

Internal contact decides, approvers sign

Per finding, choose one

- **Remediate** — the vendor must fix it. Due date by severity: High 30 days, Moderate 90, Low 180. Critical must be fixed before approval.
- **Accept risk** — write the business justification. It is routed for approval and expires after at most 12 months.

How the internal contact takes part without a login

Each finding decision is a task link (same mechanism as the IRA link) emailed to the requester: they recommend Remediate or Accept with a justification. The formal risk acceptance is signed by approvers, who are Supreme Risk users.

Approvals

Low: internal contact's manager (3 days). Moderate: business unit leader, then TPRM lead (5 days). High or Critical: business unit leader, then CISO (10 days). Rejected acceptances go back to Remediate.

Contract controls

Before approval, Legal attests the required clauses for the tier. Whenever the Personal and Sensitive Data pack is on, a Data Processing Agreement is a required control, not optional.

System

Tracks every due date, reminds owners, and records each acceptance in the risk register with its expiry.

Moves on when every finding is Closed, Accepted, or scheduled for remediation after approval with an agreed date. **APPROVAL**

 Findings marked Remediate go to the vendor

7b. Vendor fixes gaps

Vendor security contact, in the same portal

Sees

Only findings marked Remediate, each with the gap, the expected control and the due date. Accepted findings and internal notes are not shown.

Does

Uploads remediation evidence or a dated plan and marks the item Ready for review.

Then

The analyst validates and closes the finding, or sends it back with what is still missing. Repeats until every remediation item is closed.

 All findings resolved

8. Approve and monitor

System, on the final approval

System

- Sends the approval notice to the requester, internal contact, procurement and legal: tier, residual risk, accepted risks, open remediation dates.
- Sets the reassessment date by tier: Critical and High 12 months, Moderate 24, Low 36. Reminds 30 days before.
- Tracks the contract renewal date and warns 90 days before.
- Watches for expiring evidence (SOC 2, ISO) and expiring risk acceptances, and creates a task 30 days ahead.

Internal contact

Keeps owning the vendor through task links, never a login: a "report a change" button on every approval notice and attestation that emails a fresh 14-day task link to the registered requester address (old emails give nothing); the change re-runs the IRA for that engagement; an annual attestation link; reassessment requests; and an offboarding request link. If their involvement grows, GRC can invite them to a business-owner account.

Moves on when done. Monitoring and reassessment take over. ACTIVE

Appendix A — IRA questions (what the requester sees)

Closed answers only. "Don't know" is always available and is never scored. The right-hand column is internal: which factor of the risk model the answer feeds and what it switches on.

Part A — What will this vendor do for us?

ID	Question	Answer choices	Internal mapping
A1	What will the vendor do for us? (choose all that apply)	Software we use online / an app / an API · Hosting our data or systems in their cloud · Consulting or professional services · Work on our premises or handle our records/equipment · Staff placed with us · Hardware or equipment supply	Packs: Software and API · Cloud Hosting · Physical Delivery
A2	What information will the vendor store, process, or be able to see? (choose all that apply)	None / public only · Internal business information · Confidential business information · Personal data about employees or customers · Payment card data · Health data · Passwords or login credentials · Regulated financial data	IR-02. Internal → 0; confidential → 1; personal → 1 and floor Medium; card, health, credentials, regulated → 2 and floor Critical. Pack: Personal and Sensitive Data if ≥ 1 (DPA required at step 7)
A3	Roughly how many people's records?	None · Under 1,000 · 1,000–10,000 · 10,000–100,000 · Over 100,000	IR-03. 0 / 0 / 1 / 2 / 2; over 100,000 with personal data → floor High
A4	What access will the vendor need to our systems?	None · We exchange files or log into their site · An automated connection that reads our data · An automated connection that changes our data · Admin accounts, remote access, or a connection into our network	IR-04 and IR-05. None 0 · files 0 · reads 1 (IR-05) · changes 2 (IR-05, floor High) · admin/network 2 (IR-04, floor Critical). Packs: Software and API for automated; Privileged and Network Access for admin/network
A5	Is the service reachable from the internet or used by our customers?	Internal use only · Reachable from the internet · Part of a product or service our customers use · Both	IR-14 (internet) and IR-06 (customer-facing): 0 / 2 / 2 / 2
A6	Where will our data be stored or handled?	Our country only · Same region · Outside the region (name the countries)	IR-09: 0 / 1 / 2
A7	Will the vendor use other companies to deliver this service or handle our data?	No · Yes (name them if known)	IR-10: 0 / 2
A8	Does the service use AI to make decisions or generate content using our data?	No · Yes	IR-13: 0 / 2; Yes blocks auto-confirm and shows a GRC note (AI pack in workbook v1.1)
A9	Will vendor staff work on our premises or handle our physical records or equipment?	No · Yes	Pack: Physical Delivery (also set by A1)

Part B — How bad would it be if this vendor failed?

ID	Question	Answer choices	Internal mapping
B1	If this vendor stopped working tomorrow, what would happen?	Not much — we would manage · Inconvenience, work-arounds needed · Serious disruption within a week · Critical operations or customer commitments would stop within a day	IR-01 and IR-12: 0 / 1 / 2 / 2; "within a day" → floor Critical. Pack: Critical Operations only if "serious disruption within a week" or worse
B2	Could a problem with this vendor (failure, fraud, misuse) cost us money?	Not really · A noticeable amount · A material amount for the business	IR-07: 0 / 1 / 2; material → floor High
B3	Is this service tied to a law, regulation, licence, audit or contractual obligation?	No · Yes (name it if known)	IR-08: 0 / 2; Yes → floor High. Pack: Regulated Service
B4	If the vendor lost our data or failed publicly, how bad would it be for our customers and reputation?	Minor · Noticeable · Significant harm to customers or the brand	IR-15: 0 / 1 / 2
B5	How hard would it be to replace this vendor?	Easy — alternatives exist · Would take months · Very hard — unique technology, data or skills	IR-11: 0 / 1 / 2

Vendor security contact: name and email (optional at this stage).

Appendix B — Scoring decision (ADR-TPRM-INHERENT-RISK-SCORING, accepted)

Decision: inherent risk is scored by weighted points with direct-to-tier floors, replacing the workbook's equal-weight average. This is a policy change and is recorded separately from the build instructions.

- Weights: IR-01, IR-02, IR-04, IR-08 = 3; IR-03, IR-05, IR-07, IR-12, IR-15 = 2; IR-06, IR-09, IR-10, IR-11, IR-13, IR-14 = 1.
- Points per factor 0 / 1 / 2 as mapped in Appendix A. Score = $\Sigma(\text{points} \times \text{weight}) \div \Sigma(2 \times \text{weight})$. Bands: <20% Low, <40% Medium, <65% High, ≥65% Critical.
- Floors: Critical — card, health, credential or regulated data; admin or network access; critical operations stop within a day. High — regulatory obligation; automated connection that changes our data; material financial loss; personal data over 100,000 records. Medium — any personal data (GDPR Art. 28 documented review). Tier = max(band, floors).
- External rating: SecurityScorecard below B (<80) or BitSight below 650 raises the tier one level, never above Critical. Bump first, then auto-confirm decision. Missing rating, or rating older than 90 days, blocks auto-confirm.
- Auto-confirm requires: tier Low after bump, no unknowns, no floor, current rating on file, A8 not Yes, no override.
- Any "Don't know" → no tier is shown or stored; the engagement is "Not yet rated" until resolved.
- Why: averaging let three High answers disappear among twelve Lows; floors reflect industry practice that certain answers place a vendor directly in a tier; separating facts (packs) from impact (tier) stops severity answers being used as a substitute for "what does this vendor do".
- Consequence: existing engagements scored under the old model are re-scored on their next reassessment, not retroactively.

Appendix C — Baseline-Lite (Low tier), 14 questions

Tag these control IDs "Lite" in the workbook. Low-tier engagements receive only these; Medium and above receive all 45 Baseline questions plus packs. Deliberately excluded from Lite: VRA-007 (independent assessment), VRA-042 (penetration testing), VRA-061 (IR plan exercised), VRA-073 (subprocessors).

Control ID	Domain	Control
VRA-001	Governance	Accountable owners assigned for security and technology risk
VRA-004	Governance	Security policies approved, reviewed annually, communicated
VRA-014	Identity and Access	Access rights approved by owners before grant
VRA-016	Identity and Access	MFA for admin, remote and sensitive access
VRA-017	Identity and Access	Joiner / mover / leaver changes completed promptly
VRA-023	Human Resources	Security and privacy awareness training at hire and annually
VRA-026	Human Resources	Termination revokes access and recovers assets
VRA-039	Vulnerability Management	Internal and external vulnerability scanning
VRA-043	Vulnerability Management	Patches deployed within risk-based deadlines
VRA-053	Logging and Monitoring	Security events defined and logged on critical systems
VRA-056	Logging and Monitoring	Alerts triaged under documented severity and response targets
VRA-059	Incident Response	Approved incident-response plan with roles and communications
VRA-062	Incident Response	Customer notification requirements identified and met
VRA-071	Third-Party Management	Suppliers assessed before access to data or systems

Appendix D — AI and Automated Decisions pack (draft for workbook v1.1, not live)

Six questions to add as a ninth pack, switched on by A8 = Yes. Until it exists, A8 = Yes only flags GRC and blocks auto-confirm.

Control ID	Domain	Control
AI-1	Data use	Is our data used to train, fine-tune or improve any model, and can we opt out contractually and technically?
AI-2	Model providers	Which underlying model or AI service providers are used (sub-processors), and where do they process our data?
AI-3	Human oversight	Is there human review before AI outputs affect a person, a payment or a business decision?
AI-4	Logging	Are prompts and outputs logged, for how long, and can we obtain them for audit or dispute?
AI-5	Safety testing	Is the system tested for prompt injection, data leakage between tenants and unsafe or biased output, with results available?
AI-6	Failure and liability	What happens when the model is wrong or unavailable — fallback process, correction, and who bears liability?

Quick reference

Step	Who	Key rule	Status after
1 GRC record	GRC analyst, from requester email	Vendor + engagement; sanctions + rating pre-screen; IRA generated	INTAKE
1a / 1b Send IRA	App or analyst	Secure IRA link to requester, no login; email or copy + Mark as sent; 5-day task	INTAKE
2 IRA	Requester via link	Part A facts (9) + Part B impact (5), plain language, Don't know allowed	TIER_REVIEW
3 GRC review	System, analyst	Packs from Part A; tier from Part B + floors (personal data ≥ Medium); Don't know = no tier; Low gets Baseline-Lite (14)	READY_TO_SEND
4a / 4b Send	Analyst	One single-use 14-day link; Mark as sent on copy	AWAITING_VENDOR
5 Vendor answers	Vendor contact	Baseline + selected packs; Yes/Partial/No/N/A + evidence	SUBMITTED
6 Review	Analyst	Yes 0, Partial 2×w, No 4×w; <15 / <35 / <60 / ≥60	FINDINGS_OPEN
7 Decide	Internal contact, approvers	Remediate 30/90/180 days or accept ≤12 months	APPROVAL
8 Approve	System	Reassess 12 / 24 / 36 months; renewal warning 90 days	ACTIVE